isec
Engenharia

wazuh.

SEGURANÇA 2025/2026

ISEC- Instituto Superior de Engenharia de Coimbra

Ramo de Redes e Administração de Sistemas

José Neto 2023140616
Renato Santos 2019143713
Orlando Santos 2023134097

Coimbra 09, Junho de 2026

Índice

1 – Introdução

2 – Planeamento e Infraestrutura

3 – Sistemas HIDS e XDR

4 – Sistemas IPS e IDS

5 – Wazuh Arquitetura

6 – Análise & Criação de Políticas de Proteção

7 – Conclusão

2 – Planeamento da Infraestrutura

A infraestrutura consiste em 2 redes, uma protegida e uma desprotegida.

No qual cada uma possui um determinado número de equipamentos e Software preparados para efeitos de testes.

REDE PROTEGIDA

- ❑ Rede com hosts monitorados e defesas contra possíveis ataques MITM e externos;
- ❑ Rede com logs previamente configurados;
- ❑ Local onde localiza-se o Wazuh-Server.

REDE NÃO PROTEGIDA

- ❑ Rede sem qualquer tipo de proteções;
- ❑ Rede super vulnerável a ataques MITM e externos.

2.1 – Topologia

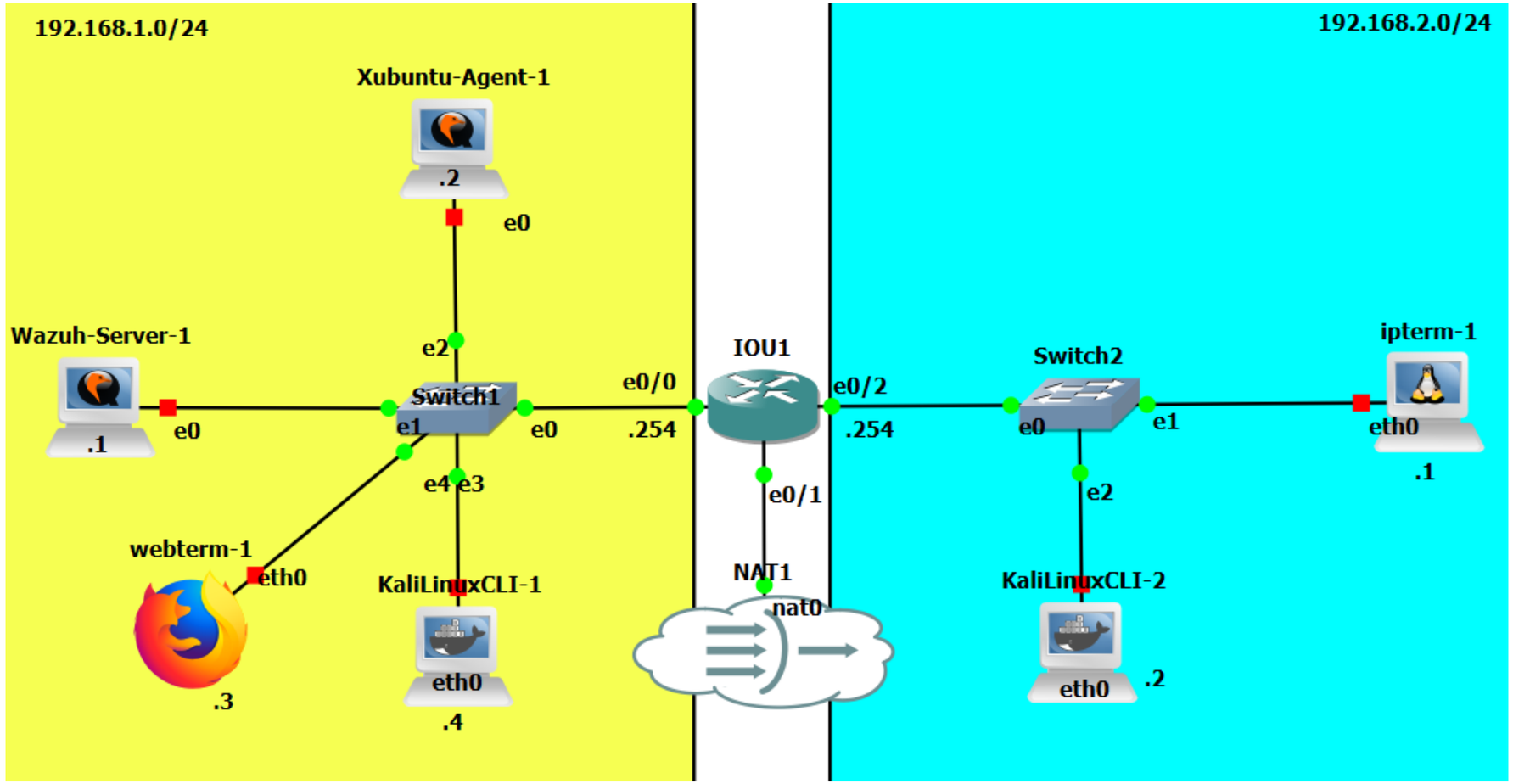


Figura nº1 – Topologia da Experiência

2.2 – Endereçamento da Topologia

As duas redes foram planeadas com endereçamento estático, para facilitar as experiências realizadas.

Rede Protegida	Endereço IP	Designação
192.168.1.0	192.168.1.1	Wazuh-Server-1
	192.168.1.2	Xubuntu-Agent-1
	192.168.1.3	Webterm-1
	192.168.1.4	KaliLinuxCLI-1

Tabela 1 – Endereçamento Rede Protegida

Rede Desprotegida	Endereço IP	Designação
192.168.2.0	192.168.2.1	ipterm-1
	192.168.2.2	KaliLinuxCLI-2

Tabela 2 – Endereçamento Rede Não Protegida

2.3– Software Utilizado



















2.4 – Ferramentas Pentesting Utilizadas

As ferramentas de pentesting utilizadas foram o Hping3, o NMAP e Hydra.



Figura nº2 3 e 4 – Ferramentas Hping, Hydra e Nmap

Download Hping for Windows 11, 10, 7, 8/8.1 (64 bit/32 bit)
Kali Linux / Packages / hydra · GitLab
Llega la nueva versión de Nmap 7.80 y estos son sus cambios mas importantes | Pacosite's Blog

3 – Sistemas HIDS, XDR, SIEM

- **XDR (Extended Detection and Response):**

Segurança em múltiplas camadas para toda a organização. Cruza informações de endpoints, redes, servidores e cloud para identificar ameaças.

- **HIDS (Host-based Intrusion Detection System):**

Atua exclusivamente na máquina (host) onde está instalado e inspeciona tráfego interno, logs e integridade de ficheiros para detetar intrusões.

- **SIEM (Security Information and Event Management):**

O "cérebro" que centraliza a segurança da rede, recolhe e analisa eventos de todos os equipamentos (routers, firewalls, servidores) para gerar alertas em tempo real.

4 – Sistemas IDS e IPS

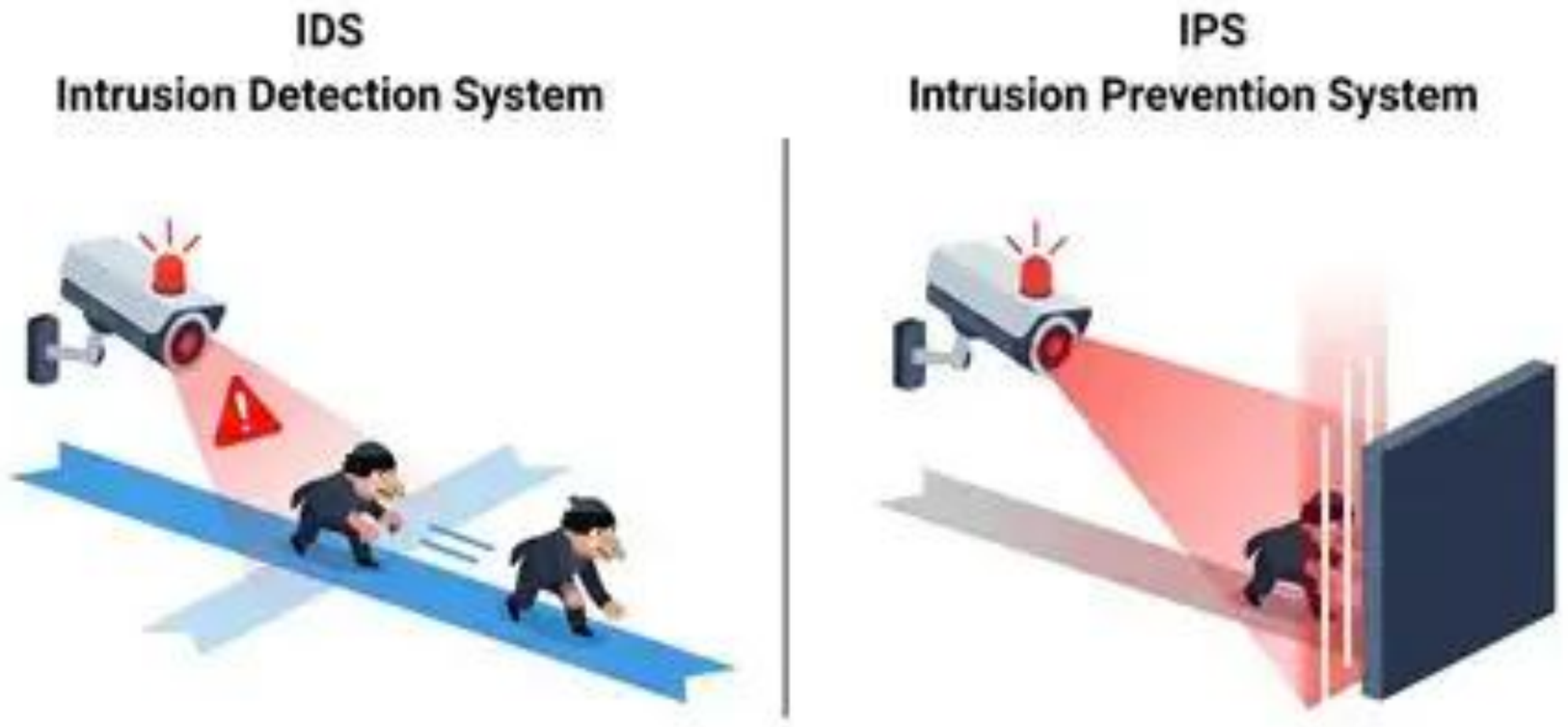


Figura nº6 – IDS VS IPS

IPShttps://lighthouseintegrations.com/blog/what-is-an-intrusion-detection-system/

5 – Wazuh Arquitetura

wazuh.

5.1 – Componentes

- O funcionamento do Wazuh depende da interação entre vários componentes. Cada um tem uma função específica no processo de recolha, indexação, visualização e análise dos eventos.

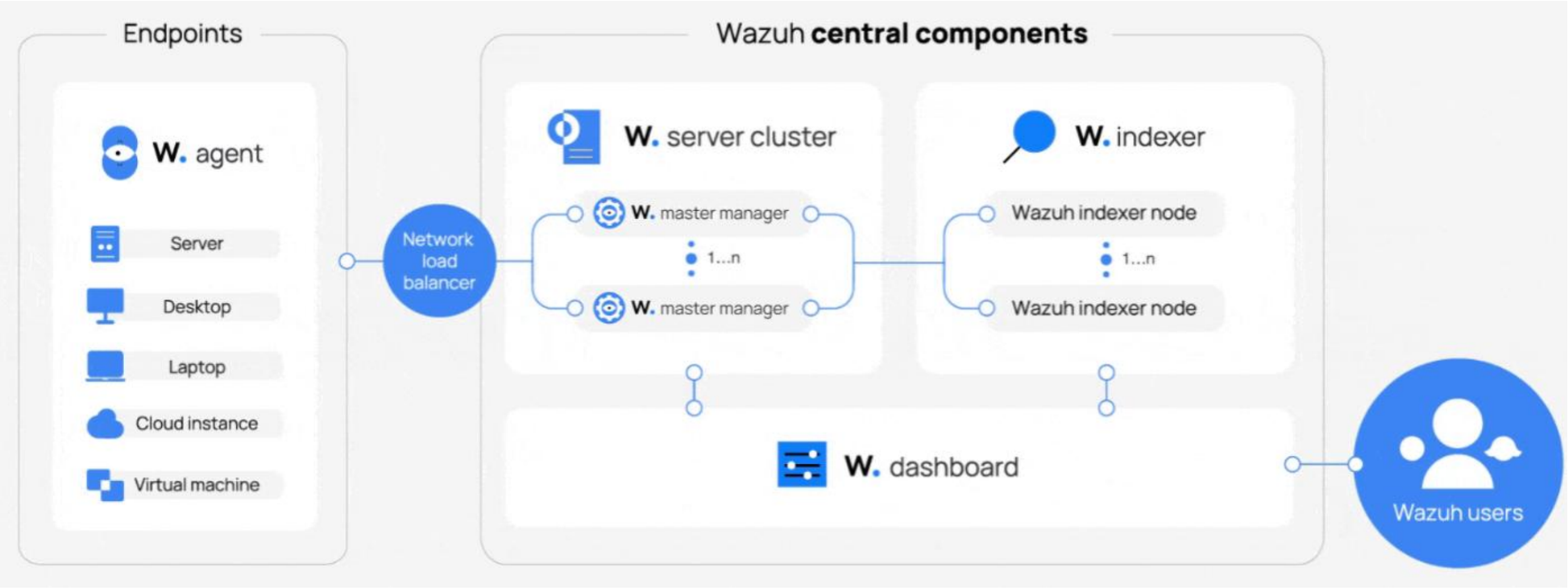


Figura nº8 – Componentes Wazuh

5.1.1 – Server

- O **Wazuh Server** (composto pelo *Manager* e pelo *Filebeat*) atua como o motor central que recebe, analisa e correlaciona os dados dos agentes, aplicando regras de segurança para gerar alertas.

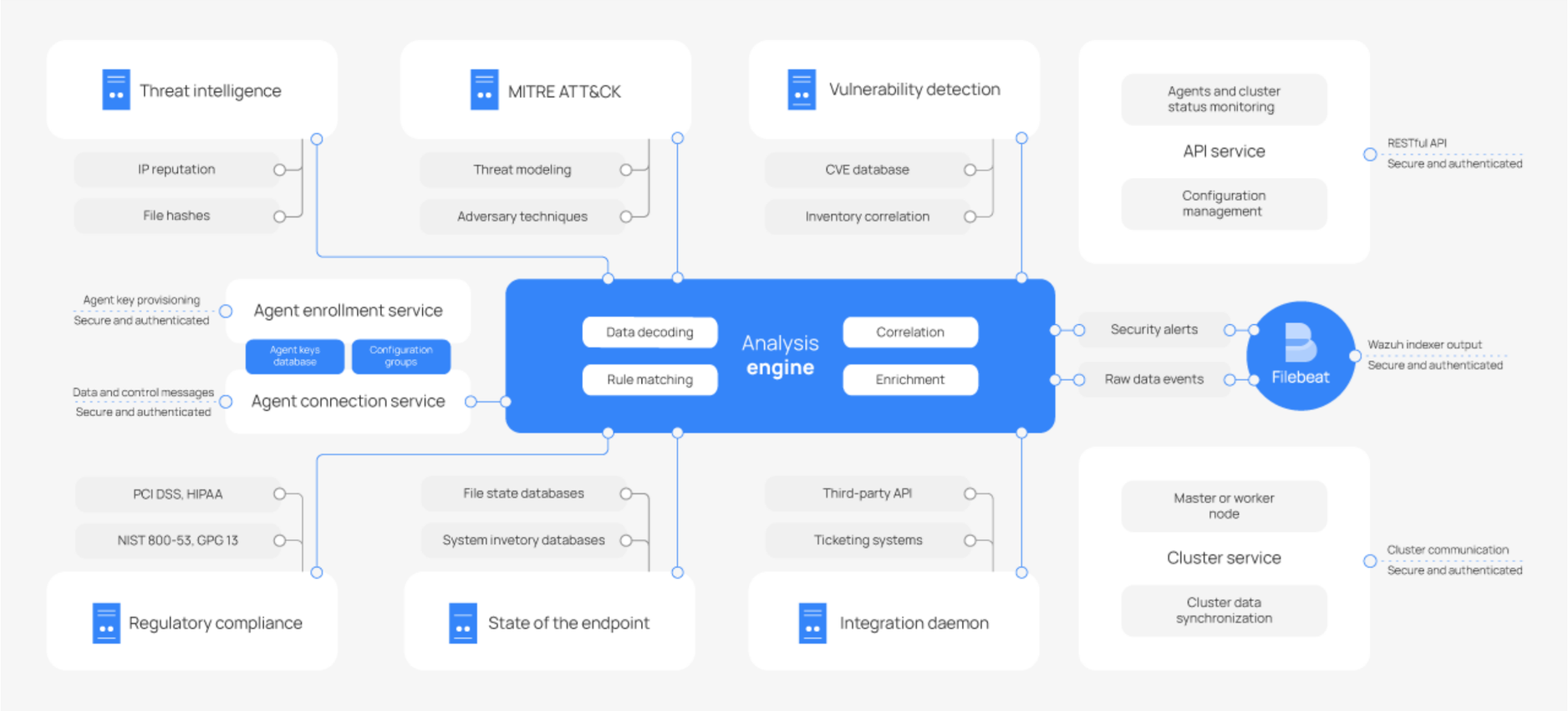


Figura nº9 – Arquitetura Server

5.1.2 – Indexer

- Funciona como o motor de armazenamento e pesquisa altamente escalável, responsável por indexar todo o volume de dados.

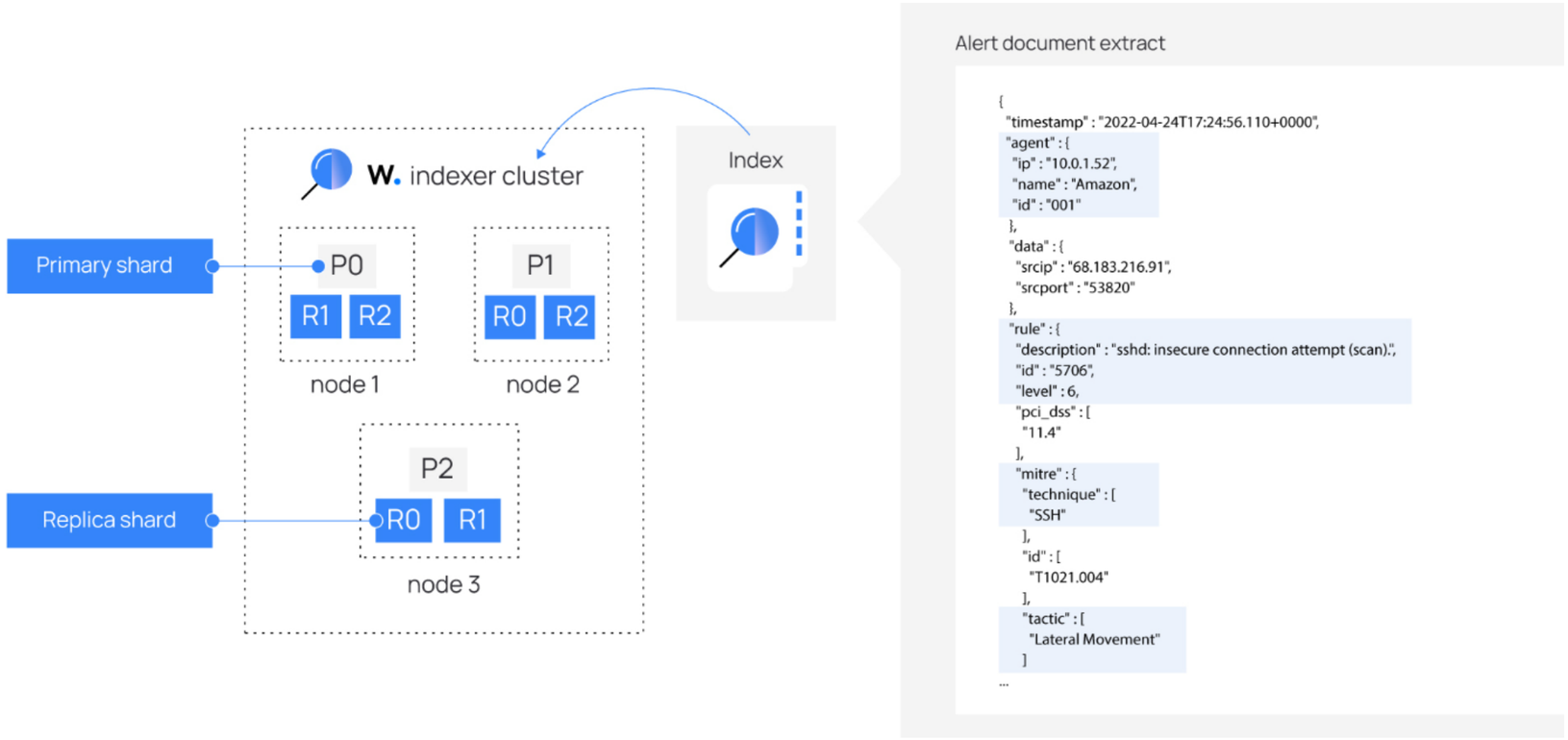


Figura nº10 – Arquitetura Indexer

5.1.3 – Dashboard

- É a interface web interativa que se liga ao Indexer, permitindo aos utilizadores visualizar rapidamente as ameaças através de painéis gráficos, gerir a configuração do sistema e investigar incidentes.

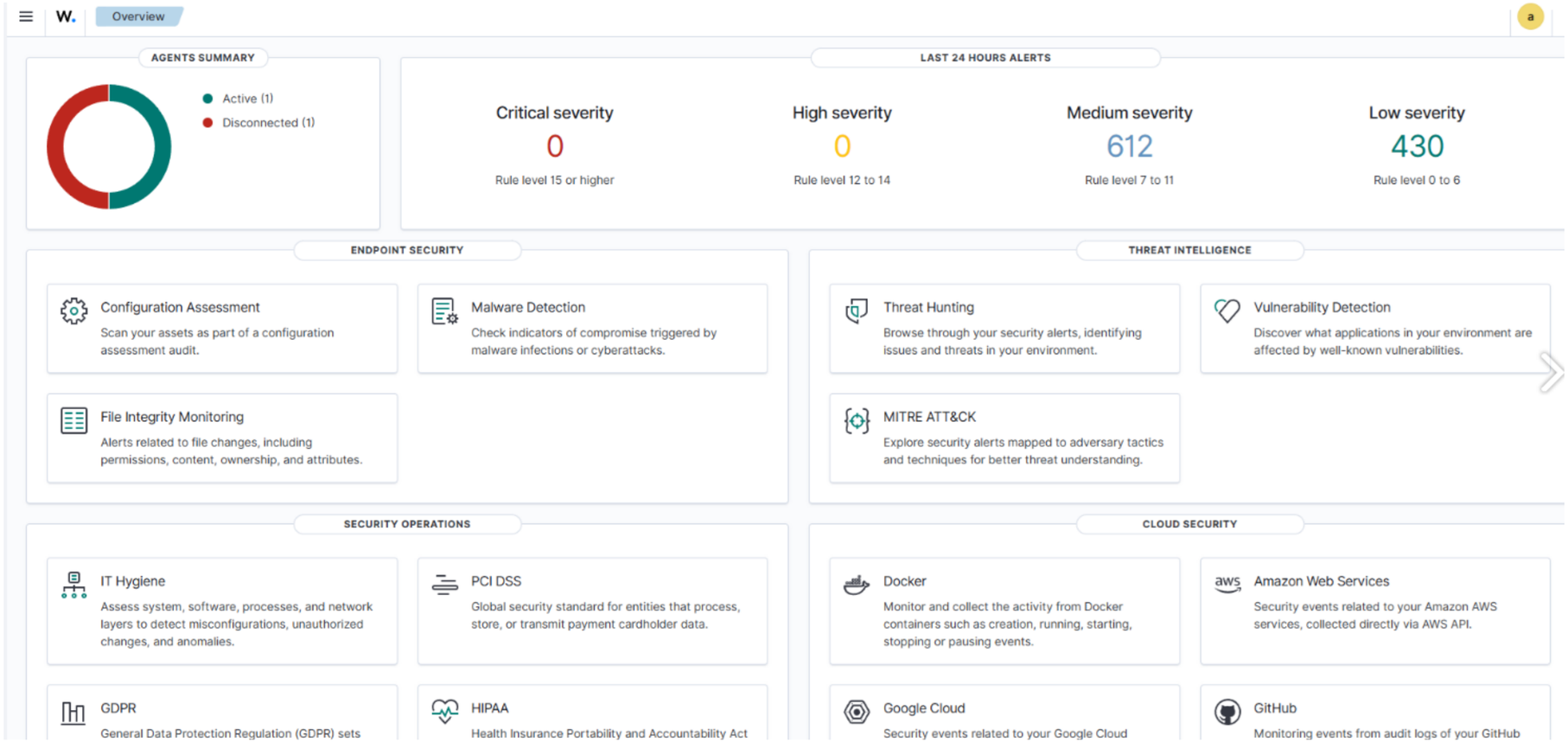


Figura nº11 – DashBoard

5.1.4 – Agent

- O Wazuh Agent é instalado nos sistemas a monitorizar, sendo responsável pela recolha e monitorização de dados de segurança locais, como logs, eventos do sistema e alterações em ficheiros.

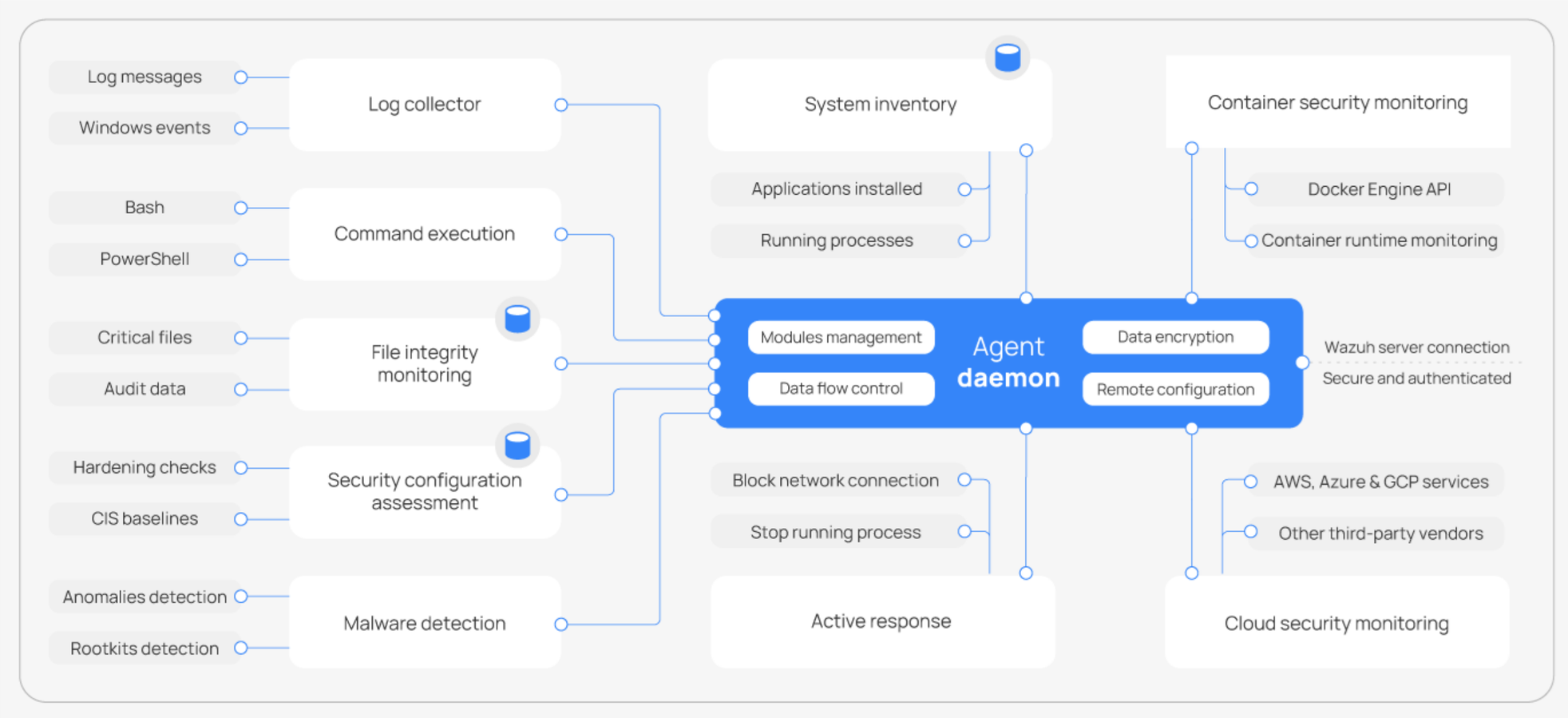


Figura nº12 – Arquitetura Agente

5.2 – Arquitetura

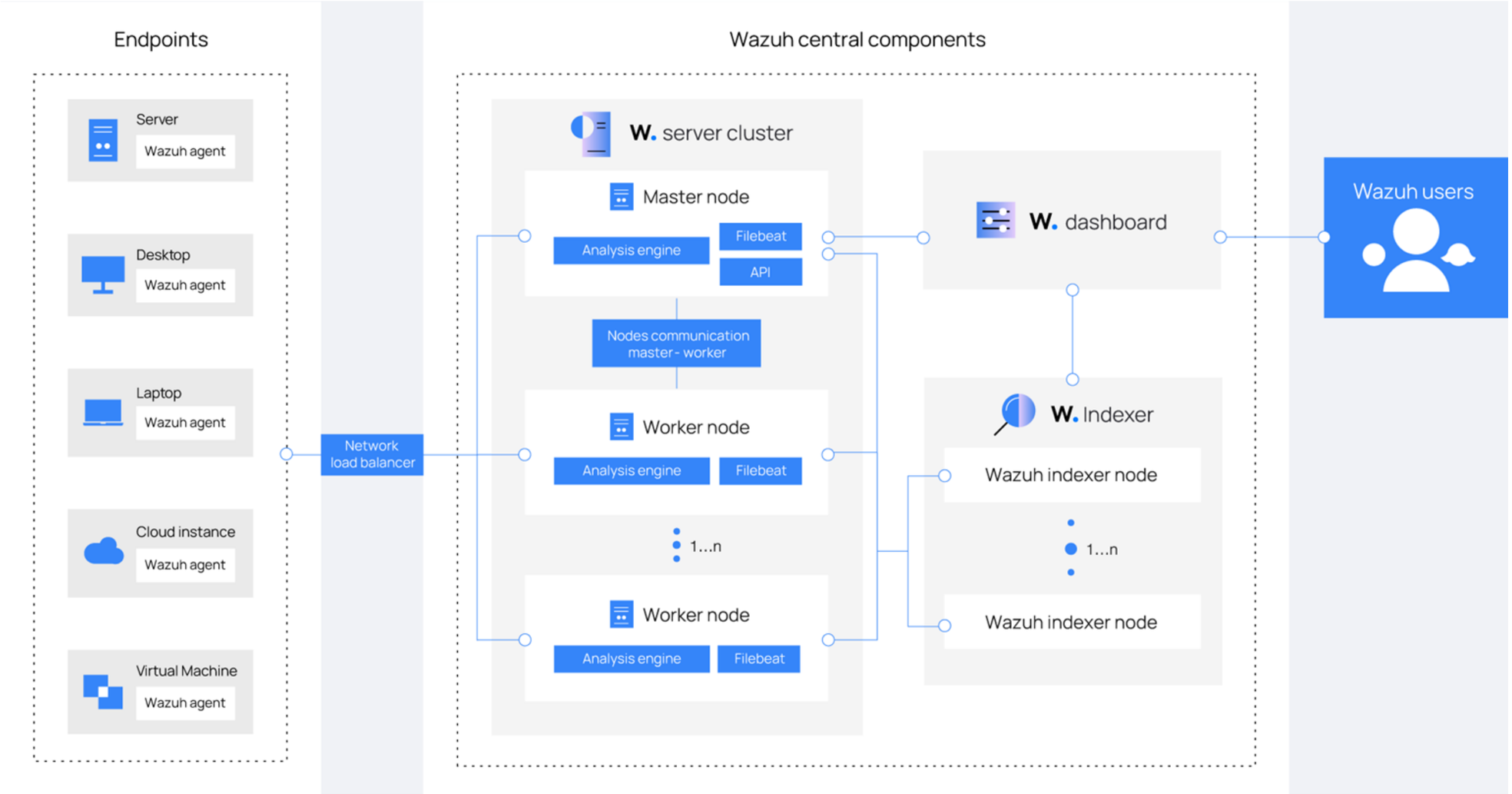


Figura nº13 – Arquiteturas Wazuh

5.2.1 – All-in-one

Os principais componentes do Wazuh ficam instalados na mesma máquina, incluindo o Wazuh Server, o Wazuh Indexer e Wazuh Dashboard. Neste modelo, todo o processo de recolha, análise, armazenamento e visualização dos eventos ocorre num único sistema.

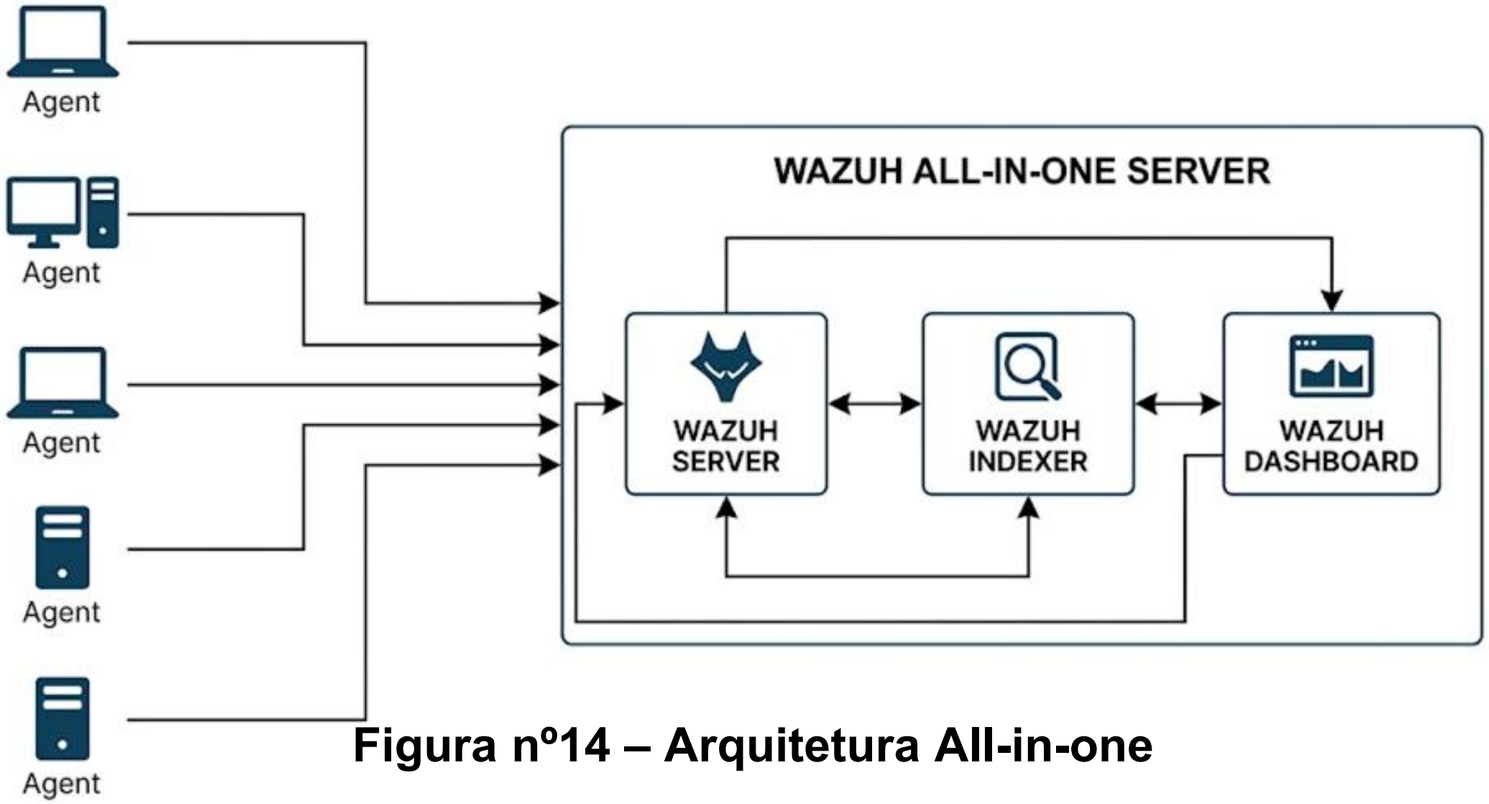


Figura nº14 – Arquitetura All-in-one

5.2.2 – Single-Node

Os principais componentes do Wazuh são distribuídos por máquinas distintas, permitindo separar responsabilidades e reduzir a concorrência direta pelos mesmos recursos de processamento, memória e armazenamento.

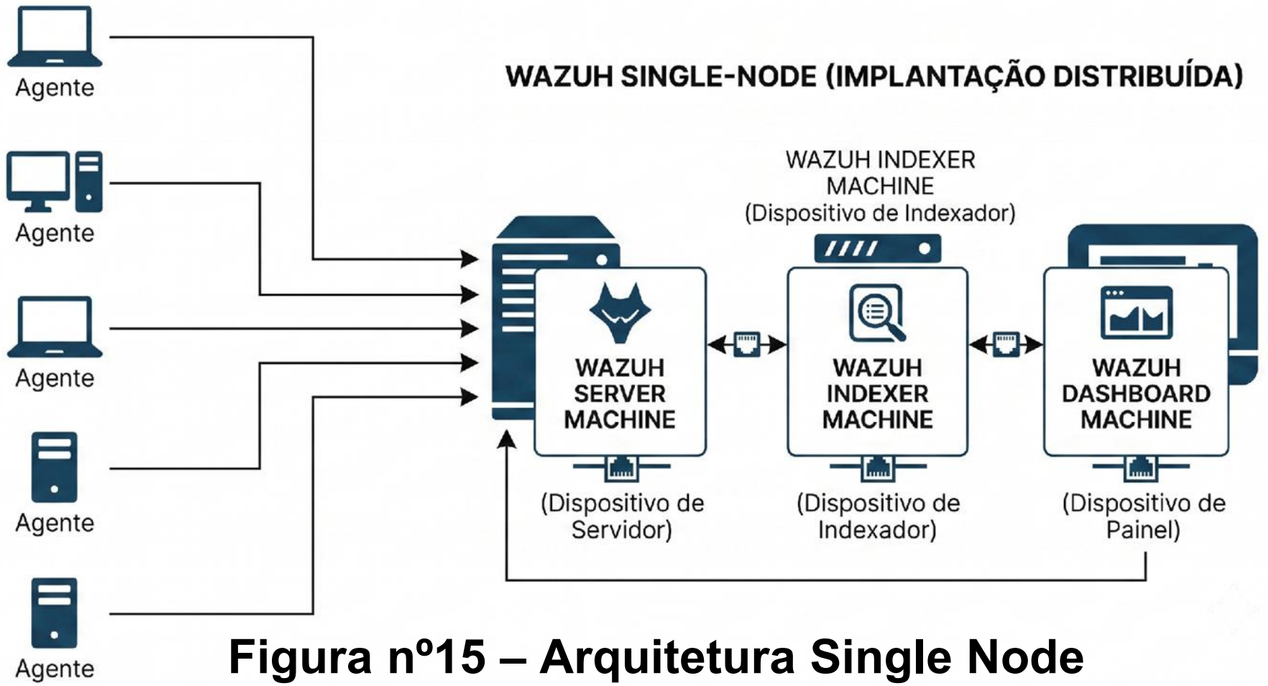


Figura nº15 – Arquitetura Single Node

5.2.3 – Multi-Node

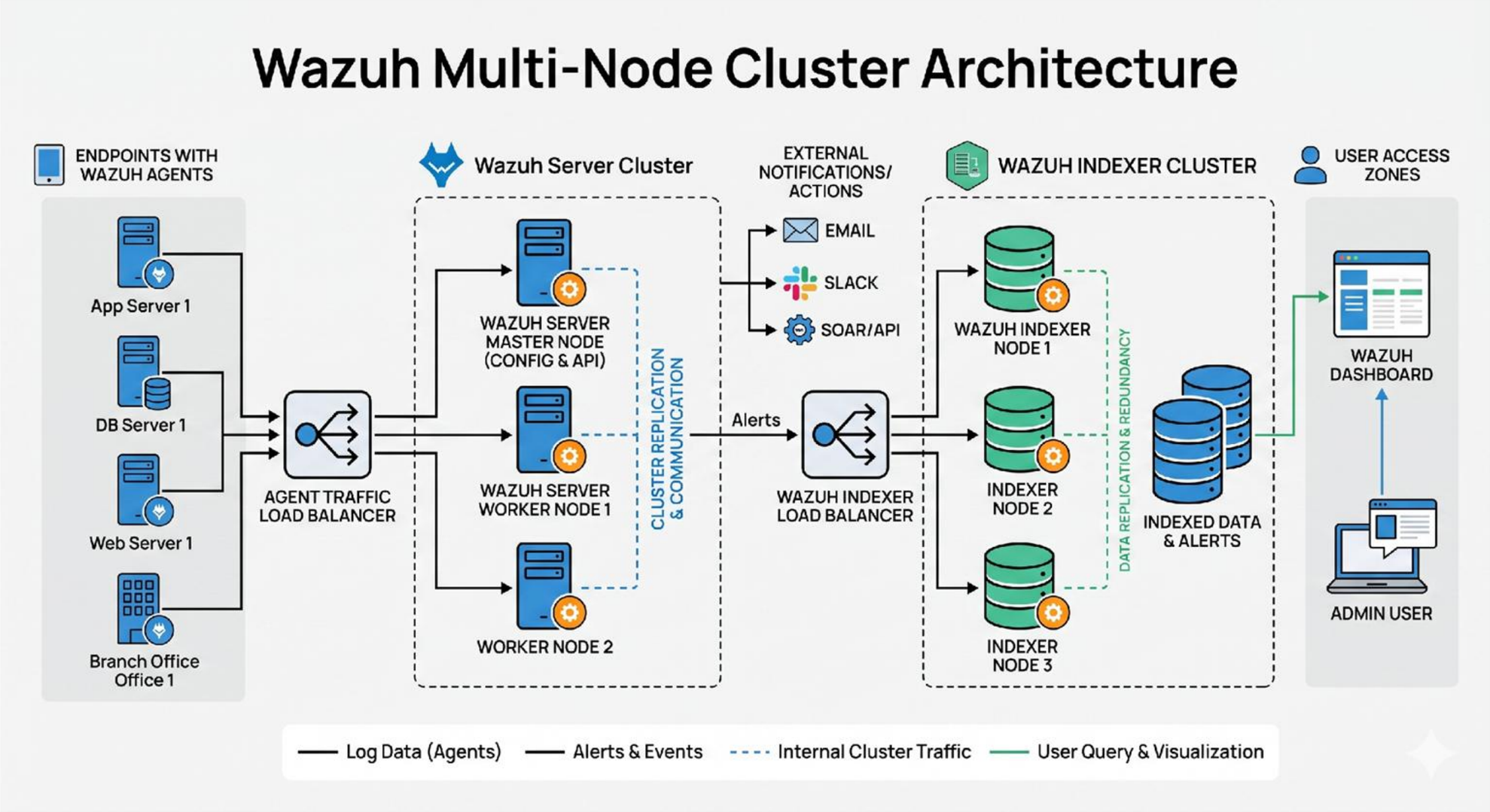


Figura nº16 – Exemplo Arquitetura Multi-Node

5.3 – Comunicação Entre Componentes

- **Registo de Agentes (Porto 1515/TCP):** Ligação com TLS para associar endpoints e gerar chaves simétricas partilhadas.
- **Envio de Eventos (Porto 1514/TCP):** Canal de comunicação seguro entre servidor e agente para a transmissão de logs e comandos.
- **Interface e APIs (Portos 443/TCP e 55000/TCP):** Acesso gráfico ao Dashboard e às APIs de gestão via protocolo HTTPS.
- **Telemetria externa (Porto 514/UDP):** Receção de logs via Syslog direto no servidor para monitorização agentless.
- **Autenticação das mensagens trocadas:** Proteção contra manipulação de logs do Wazuh (porto 1514) e consultas na interface web (porto 443).

5.3.1 – Portos Relevantes

Porto	Protocolo	Finalidade
514	UDP/TCP	Receção de mensagens de auditoria via Syslog (Agentless).
1514	TCP	Comunicação ativa e envio de eventos do Wazuh Agent para o Wazuh Server.
1515	TCP	Registo e autenticação inicial dos agentes (Enrollment).
1516	TCP	Comunicação entre nós do cluster do Wazuh Server.
9200	TCP	Acesso à API do Wazuh Indexer (comunicação restrita/autenticada).
9300–9400	TCP	Comunicação interna entre nós do cluster do Indexer.
55000	TCP	Acesso à API de gestão interna do Wazuh Server.
443	TCP	Acesso seguro exposto pelo servidor para a interface web do Dashboard.

5.3.2 – Protocolos de Criptografia

- **Criptografia Assimétrica:**

  - ECDHE(Elliptic Curve Diffie-Hellman Ephemeral) no TLSv1.3. Troca de chave simétrica. Derivação local. Chaves efémeras garantem forward secrecy.

- **Criptografia Simétrica:**

  - AES-256-CBC entre servidor e agente. Advanced Encryption Standard. Chaves de 256 bits. Cipher Block Chaining (cifra contínua eficiente e rápida).

  - AES-GCM no TLSv1.3. Chaves de 128 ou 256 bits. Galois/Counter Mode (cifra e autentica os dados em simultâneo com alto desempenho).

- **Autenticadores de mensagens:**

  -AEAD(Authenticated Encryption with Associated Data) no TLSv1.3.

  -Autenticação e cifra efetuadas ao mesmo tempo.Protocolo do Wazuh: Hash-then-Encrypt. Hash criptográfico (SHA-1) afixado ao log/comando.

5.4 – Estrutura de Ficheiros e Sintaxe

- A informação recolhida é processada através de decoders e regras, permitindo a geração de alertas de segurança.
- Os dados são armazenados como documentos JSON;

Below, we show the structure of the ruleset directory on the Wazuh server:

```
/var/ossec/
        ├─ etc/
        |   ├─ decoders/
        |   |        └─ local_decoder.xml
        |   └─ rules/
        |            └─ local_rules.xml
        └─ ruleset/
                ├─ decoders/
                └─ rules/
```





5.4.1 – Sintaxe

```
sudo nano /var/ossec/etc/ossec.conf

<ossec_config>
  <remote>
    <connection>syslog</connection>
    <port>514</port>
    <protocol>udp</protocol>
    <allowed-ips>192.168.1.254</allowed-ips>
  </remote>
</ossec_config>
```

```
sudo nano /var/ossec/etc/ossec.conf
```

condiçoes

```
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100100</rules_id>
  <timeout>180</timeout>
</active-response>
```

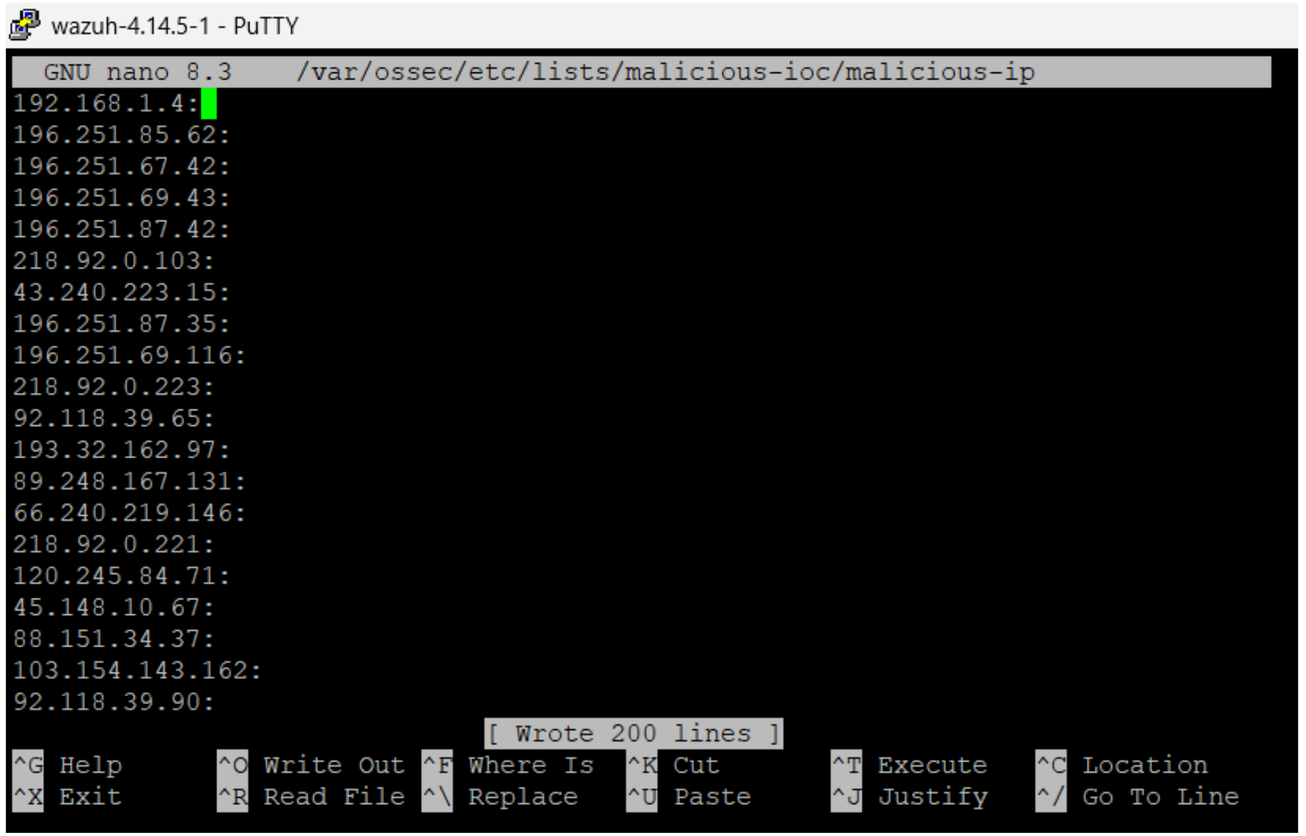
-Receção de syslogs no Wazuh server

6- Análise & Criação de Políticas de Proteção

- A configuração das políticas de segurança aplicadas aos sistemas do laboratório, recorrendo às capacidades IDS/IPS do Wazuh.
- Têm objetivo definir estratégias de defesa adequadas à superfície de ataque explorada e validar a eficácia das resposta do sistema consoante a exposição às ameaças.
- A configuração de políticas de proteção contra ataques de Syn-flood, Brute-Force, Scan de portos e o bloqueio de um ip malicioso foram elaboradas de forma a testar a eficácia do sistema.

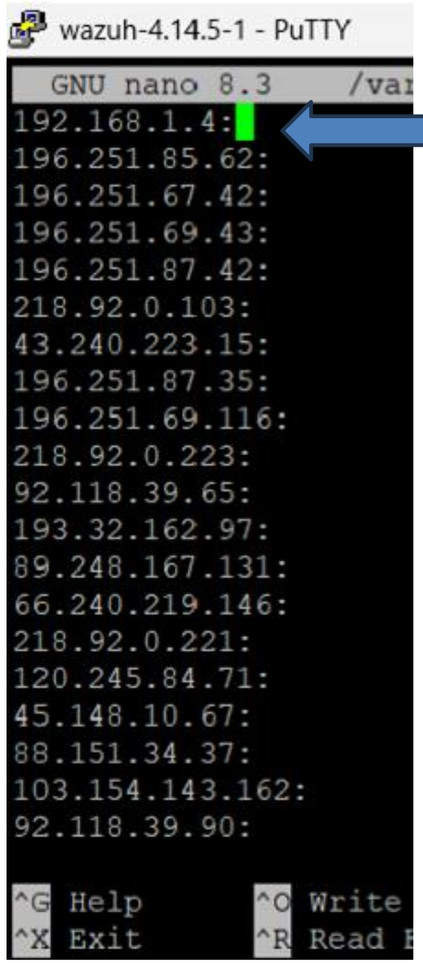
6.1-Adição a lista de endereços maliciosos

- O Wazuh já inclui uma lista de reputação para IPs maliciosos no seu conjunto de regras padrão, este esta localizado no **path /var/ossec/etc/lists/malicious-ioc/malicious-ip,** esta configuração é realizada no servidor.



6.1.1-Setup & Configuração

```
sudo -i
sudo nano /var/ossec/etc/lists/malicious-ioc/malicious-ip
```



Adicionar ip malicioso

Criação de regra de deteção
pag31

```
sudo nano /var/ossec/etc/rules/local_rules.xml
```

```
<group name="local, ip_reputation,">
  <rule id="100100" level="10">
    <if_group>web|attack|attacks|accesslog</if_group>
    <list field="srcip" lookup="address_match_key">etc/lists/malicious-ioc/
    malicious-ip</list>
    <description>Acesso Web bloqueado de um IP malicioso conhecido: $(srcip)
    .</description>
  </rule>
</group>
```

6.1.1-Setup & Configuração

- Para transformar a deteção (IDS) numa ação preventiva (IPS), é necessário que o sistema reaja à regra 100100 cortando a comunicação. Edita-se o ficheiro ossec.conf do Wazuh Server : sudo nano /var/ossec/etc/ossec.conf e adicona-se a seguinte regra:

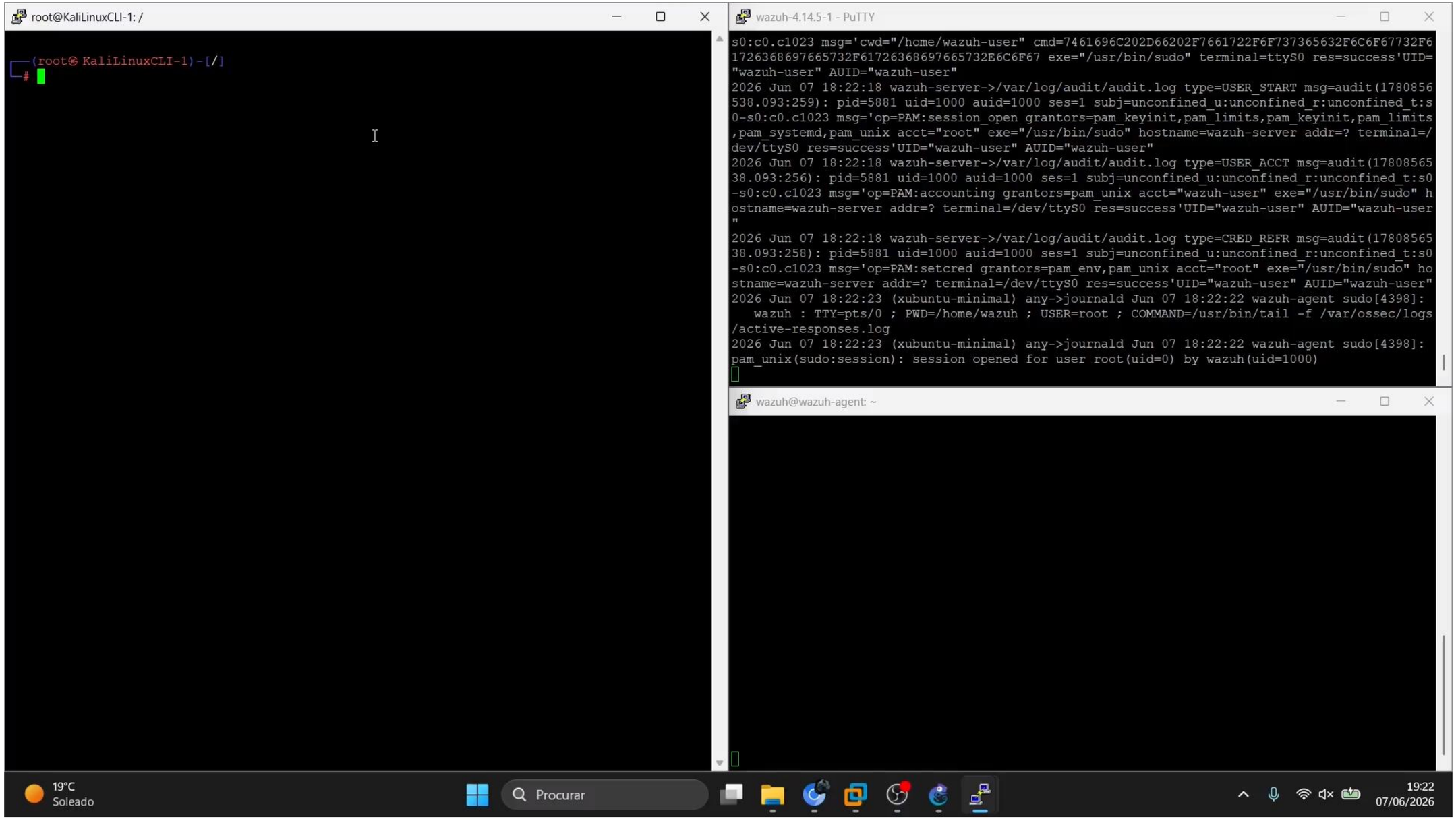
```
<active-response>
<command>firewall-
drop</command>
<location>local</location>
<rules_id>100100</rules_id>
<timeout>180</timeout>
</active-response>
```

6.1.1-Setup & Configuração

- Para que o Wazuh Server consiga processar estes eventos e gerar os alertas associados aos grupos indicados é fundamental garantir que o agente lê e envia os conteúdos deste ficheiro para o servidor.
- Foi adicionado o seguinte bloco na secção <ossec_config> para definir o formato e localização de logs locais

```
<localfile>
<log_format>apache</log_format>
<location>/var/log/apache2/access.log</location>
</localfile>
```

6.1.2 – Demonstração



6.2-Ataques de força bruta SSH & TELNET

- Adotou-se uma política de segurança comportamental ou condicional. Em vez de bloquear o acesso de forma imediata na tentativa de uma ligação de um IP específico, o servidor permite algumas falhas nas credenciais de acesso (assumindo erros do utilizador).
- O Wazuh possui regras nativas de correlação temporal para identificar estes ataques:

Regra 5712: Ataque de força bruta SSH recorrendo a utilizadores inexistentes

Regra 5763: Ataque de força bruta SSH recorrendo a utilizadores válidos (falhas repetidas de password).

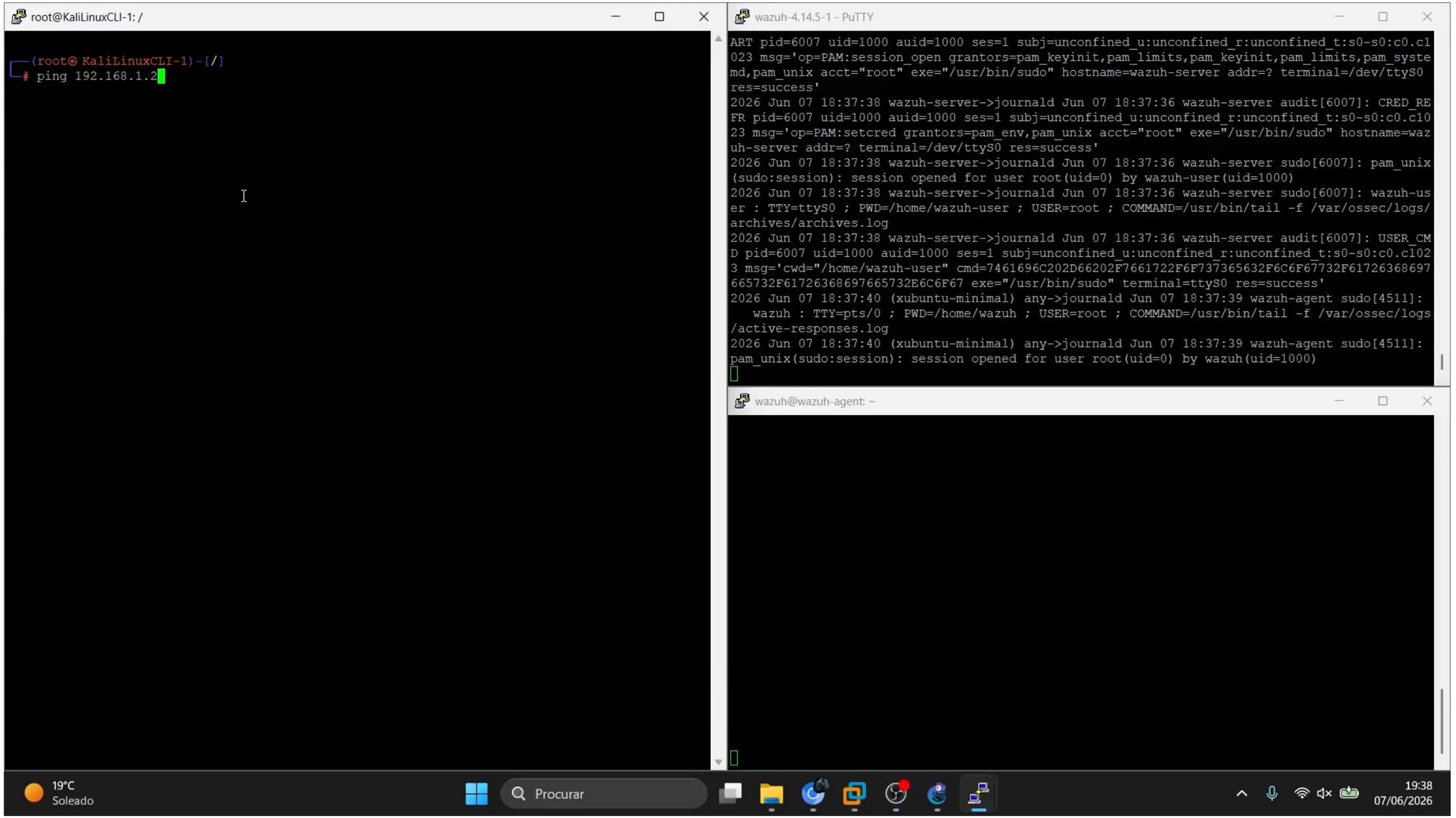
Regra 5551: Ataque de força bruta a módulos PAM(Plugable Authentication Mode)

6.2.1-Setup & Configuração

- Estas regras foram adicionadas á resposta ativa do Wazuh criada anteriormente, mapeando o script firewall-drop e às regras de brute force

```
<active-response>
<command>firewall-drop</command>
<location>local</location>
<rules_id>100100,5712,5763,5551</rules_id>
<timeout>180</timeout>
</active-response>
```

6.2.2 – Demonstração



6.3 – Proteção de Synflood & Scan de Portos

- Esta secção, as interfaces do router ligadas às duas redes privadas serão protegidas contra ataques de varrimento de portos (Port Scans) e SYN Floods. A rede 192.168.1.0/24 e o agente também serão protegidos contra estes ataques vindos da rede 192.168.2.0/24;
- Serão estabelecidas políticas de segurança IPS dinâmicas, de forma a prevenir que o ataque afete tanto os equipamentos de rede como os sistemas terminais.

6.3.1 – Configuração

```
ip tcp intercept mode intercept
ip access-list extended MASTER_POLICY
permit tcp host 192.168.1.1 host 192.168.1.254 eq 23
permit tcp any host 192.168.1.254 eq 80 log
permit tcp any host 192.168.2.254 eq 80 log
permit tcp any any eq 80 log
deny tcp 192.168.2.0 0.0.0.255 host 192.168.1.2 log
deny tcp any host 192.168.1.254 log
deny udp any host 192.168.1.254 log
deny tcp any host 192.168.2.254 log
deny udp any host 192.168.2.254 log
permit ip any any
exit
interface Ethernet0/0
ip access-group MASTER_POLICY in
exit
interface Ethernet0/2
ip access-group MASTER_POLICY in
exit
```

Listagem : Configuração do router e ACL como sensor de rede

6.3.1 – Configuração

sudo nano /var/ossec/etc/decoders/local_decoder.xml

```
<decoder name="cisco-ips-custom">
<prematch>%SEC-6-IPACCESSLOG</prematch>
</decoder>
<decoder name="cisco-ips-custom-fields">
<parent>cisco-ips-custom</parent>
<regex>tcp (\d+.\d+.\d+.\d+)\(\d+\) ->
(\d+.\d+.\d+.\d+)\(\d+\)</regex>
<order>srcip, dstip</order>
</decoder>
```

Listagem :Criação de um Decoder

6.3.1 – Configuração

```
sudo nano /var/ossec/etc/rules/local_rules.xml
```

```
<group name="cisco,ios,ips,">
<rule id="100300" level="3">
<decoded_as>cisco-ips-custom</decoded_as>
<match>IPACCESSLOG</match>
<description>Cisco syslog: trafego apanhado na ACL.</description>
</rule>
<rule id="100301" level="12" frequency="2" timeframe="60">
<if_matched_sid>100300</if_matched_sid>
<match>denied</match>
<description>IPS: Possivel scan de portos detetado. A ativar Null Route!</
description>
<mitre><id>T1046</id></mitre>
</rule>
<rule id="100302" level="10" frequency="10" timeframe="10">
<if_matched_sid>100300</if_matched_sid>
<match>permitted</match>
<description>IPS: Possivel SYN Flood detetado. A ativar TCP Intercept!</
description>
<mitre><id>T1498</id></mitre>
</rule>
</group
```

Listagem : Criação de regras para deteção de Scans e Floods

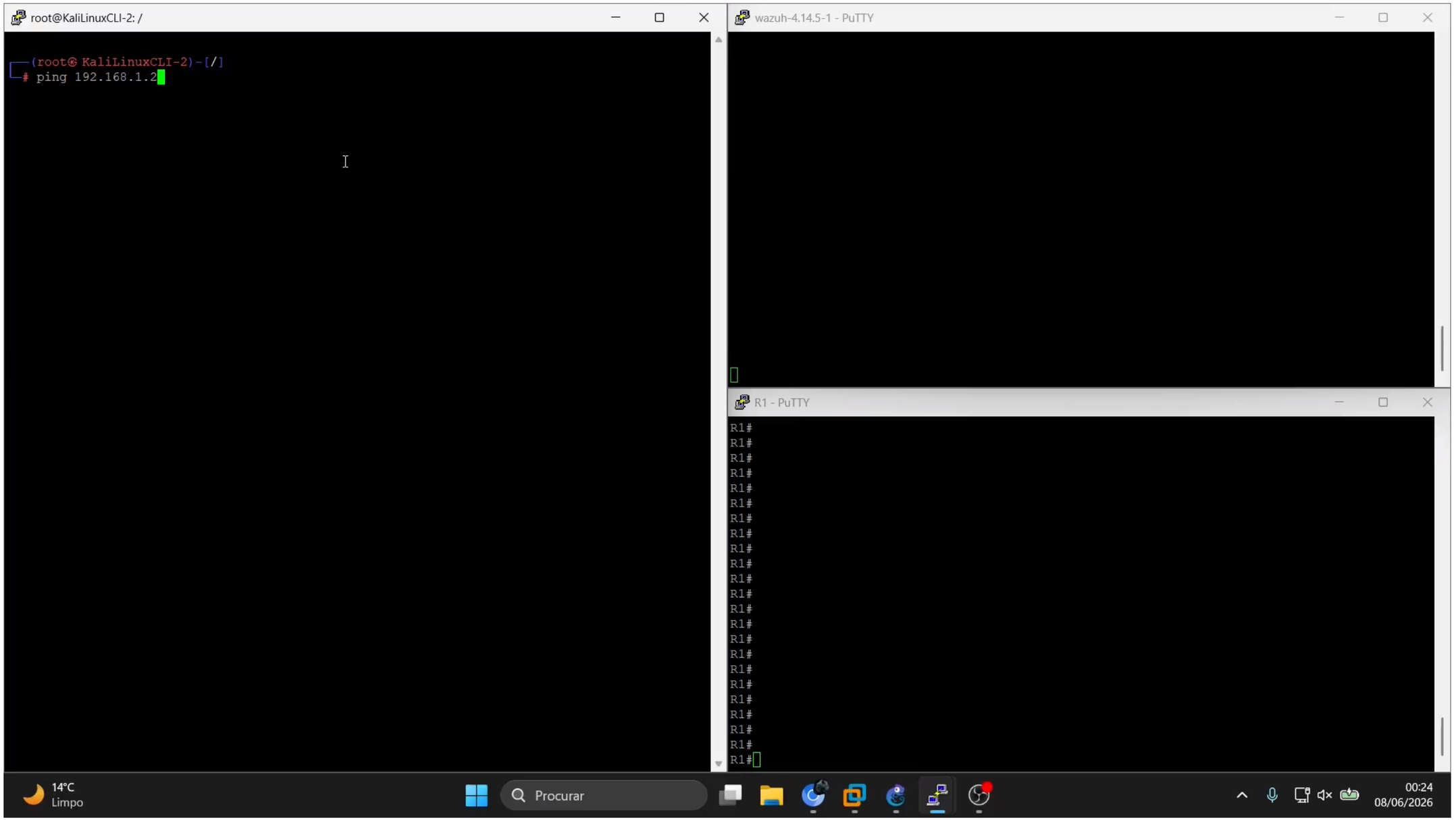
6.3.1 – Configuração

sudo nano /var/ossec/etc/ossec.conf

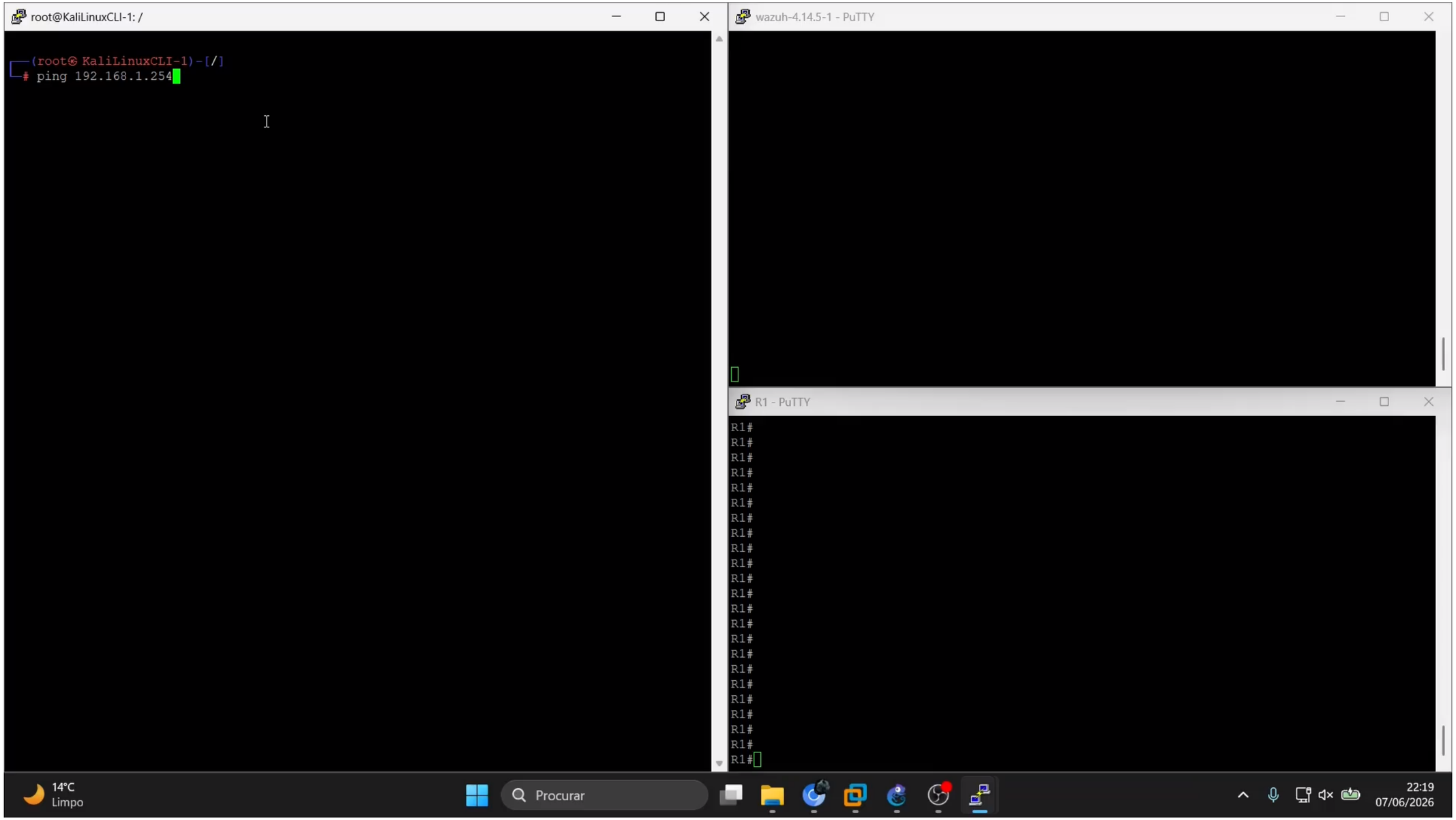
```
<command>
<name>cisco-ips</name>
<executable>cisco_ips.py</executable>
<timeout_allowed>yes</timeout_allowed>
</command>
<active-response>
<command>cisco-ips</command>
<location>server</location>
<rules_id>100301</rules_id>
<timeout>600</timeout>
</active-response>
<active-response>
<command>cisco-ips</command>
<location>server</location>
<rules_id>100302</rules_id>
<timeout>600</timeout>
</active-response>
```

Listagem : Associação das regras à Active Response

7.3 – Bloqueio Syn-flood



6.3.2 – Bloqueio Scan de Portos



Conclusão

Momento Q & A

Wazuh

José Neto | Renato Santos | Orlando Santos

ISEC - Departamento de Informática e Sistemas